



CRA Risk Assessment Demo — SecureLock One

Walking through all 10 assessment sections



About the Product

SecureLock One v2.1

A consumer IoT smart door lock designed for residential and small business use. Enables keyless entry via PIN, RFID card, fingerprint, or mobile app — with full remote lock/unlock capability via cloud connection.

- Access logs stored in cloud, viewable via companion app
- Integrates with Amazon Alexa and Google Home

CRA Category

Default — Self-Assessment

Product Type

Consumer IoT Device

Version

v2.1



Product Identity

What We Captured

Product Name

SecureLock One — v2.1

CRA Category

Default — self-assessment, no notified body required

Product Type

Consumer IoT device



Why It Matters

The CRA category directly determines the conformity assessment route. Default-class products are permitted to self-assess — no third-party notified body is required. Getting this classification right is the essential first step of the entire assessment.

SECTION B

Intended Use & Users

Users

General consumers (non-technical) and small/medium business staff

Deployment

Home/residential and office environments

Expected Lifetime

5–10 years

 **Why It Matters:** A longer product lifetime increases the exposure window for future, currently unknown threats. Non-technical users significantly raise the risk of accidental security bypass through misconfiguration or weak credential choices.



Reasonably Foreseeable Misuse

1

High-Risk Deployment

Used as access control for server rooms or secure shared-office areas

2

Network Pivot Point

Attacker exploits device as a stepping stone to reach internal network systems

3

Unauthorised Physical Entry

Remote unlock function exploited to enable physical breach

4

Accidental Bypass

Non-technical users inadvertently disable security features



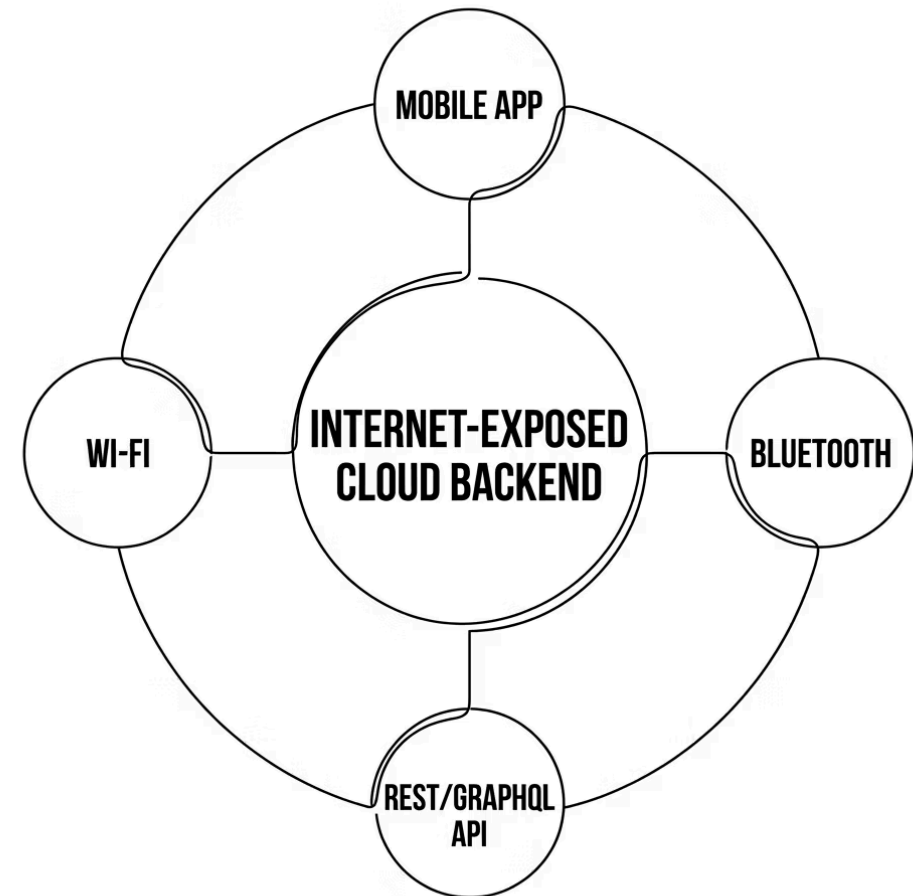
Article 13(3) Requirement

Misuse scenarios are explicitly mandated by Article 13(3) of the CRA — yet this section is **commonly absent** from manually written assessments. The AI tool surfaces these automatically.

Operational Environment & Attack Surface

Environment Profile

- **Connectivity:** Always-on, internet-exposed
- **Networks:** Public internet, Wi-Fi, Bluetooth, 4G/5G
- **Physical access:** Device is publicly accessible
- **Remote management:** Cloud admin console



❌ **Why It Matters:** Internet exposure combined with public physical accessibility creates a significantly elevated attack surface. Every exposed interface — app, Bluetooth, Wi-Fi, API — represents a potential attacker entry point.

Data, Assets & Authentication

Data Handled

- Personal data (names, email addresses)
- Authentication credentials
- Device telemetry

Storage Locations

- Cloud backend · Mobile app · Local on-device

 **High-Value Asset:** Cloud credentials — compromise enables remote unlock and exposes building entry patterns.

Authentication Posture

Method

Username + password only — no MFA

Default Credentials

User forced to change on first use 

Role-Based Access

Yes — roles enforced 

Unauthenticated Functions

None identified 

Availability & Security Logging

Availability

- **Fallback:** Physical key override always available
- **Impact if offline:** Minor inconvenience — fails to last known state
- **DoS resilience:** Partial protections only ⚠️

Security Logging

- **Coverage:** Login attempts and network events only (partial) ⚠️
- **Tamper protection:** Logs NOT protected ❌
- **Log destination:** Sent to cloud for monitoring



Annex I §3(j) Gap

Partial logging and unprotected log integrity are a direct gap against Annex I §3(j). If an attacker tampers with or deletes logs, forensic investigation and incident response become severely compromised — potentially impossible.

Updates & Patch Management

Update Mechanism

OTA automatic updates enabled

Security vs. Feature Updates

Not separated — bundled together ⚠️

Update Signing

Unknown — information gap identified ❌

Patch Process

No formal process defined ❌

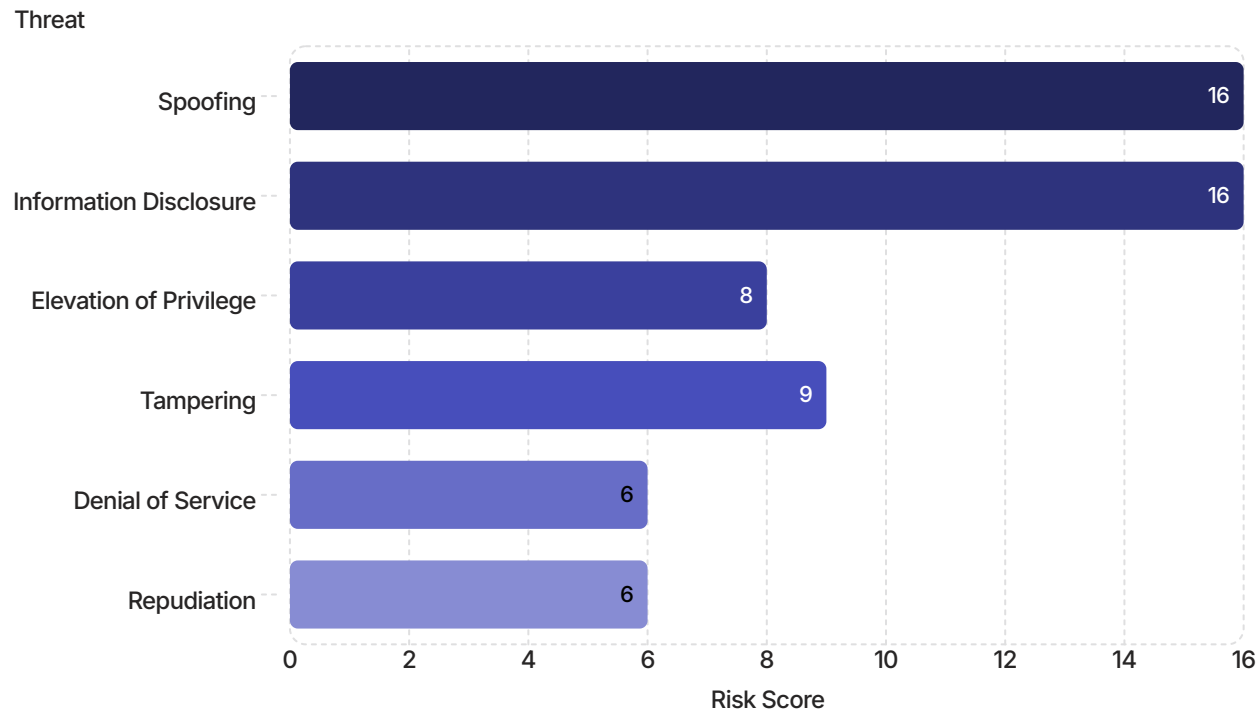


Compliance Gaps Flagged

No defined patch release process and unknown update signing status are significant gaps against **Annex I §3(k)** and **Part II §7**. These will be explicitly flagged in the generated report as action items requiring resolution before submission.

RISK SUMMARY

ISO 27005 Risk Scoring — 5×5 Matrix



Overall Posture: MEDIUM-HIGH

Two threats score HIGH (16/25): Spoofing and Information Disclosure — both driven by internet exposure and password-only authentication.

Key Gaps Identified

- No patch release process
- Unprotected security logs
- Update signing status unknown
- Partial DoS protection only